

Report on Compliance (ROC)

Document ID	Version	Owner	Effective Date	Framework	Classification
[DOC-PCI-ROC-001]	1.0	[Compliance Owner / PCI Program Manager]	[Effective Date]	PCI DSS v4.0.1	Confidential - Restricted Distribution

Purpose

This Report on Compliance documents the results of the independent assessment of [Organisation Name] against the Payment Card Industry Data Security Standard version 4.0.1.

The report is intended to provide acquiring banks, payment brands, executive management, and other authorised stakeholders with a clear, evidence-based view of whether [Organisation Name] has implemented and maintained the security controls required to protect account data within the assessed cardholder data environment.

This report covers:

- The assessed payment channels, business processes, systems, facilities, personnel, service providers, and technologies that store, process, transmit, or can impact the security of cardholder data.
- The validation approach used by the Qualified Security Assessor.
- The assessment results, including areas found to be in place, not in place, not applicable, or subject to compensating controls.
- Management actions required to address identified gaps.
- The overall compliance conclusion for the reporting period.

This report is not a penetration test report, vulnerability assessment report, audit opinion on financial statements, or general-purpose cybersecurity maturity assessment. Its purpose is specifically to document compliance with PCI DSS v4.0.1 for the defined scope and reporting period.

Reporting Period & Scope

Reporting Period

Item	Detail
Assessment type	Full Report on Compliance
Assessed organisation	[Organisation Name]
Legal entity assessed	[Legal Entity Name]
Primary business location	[Primary Address]
Assessment start date	[Start Date]
Assessment end date	[End Date]
Reporting period covered	[Reporting Period]
QSA company	[QSA Company Name]
Lead QSA	[Lead QSA Name]
Organisation assessment lead	[Internal Assessment Lead Name]
Acquiring bank / processor	[Acquirer / Processor Name]
Payment brands supported	[Visa / Mastercard / American Express / Discover / JCB / Other]
Merchant or service provider status	[Merchant / Service Provider / Both]
Merchant level or service provider level	[Level]

Scope Statement

The assessment scope includes all people, processes, technologies, facilities, and third-party services that store, process, or transmit cardholder data, or that can affect the security of the cardholder data environment.

The assessed environment includes the systems and business processes supporting the following payment activities:

Payment Channel / Process	Description	Included in Scope
E-commerce payments	Customer payments submitted through [website / application name] and routed to [payment gateway / processor]	Yes
Card-present payments	Payments accepted through [retail locations / terminals / point-of-sale estate]	Yes
Mail order / telephone order	Card details received by [call centre / back-office team] for payment processing	[Yes / No]
Recurring billing	Stored payment credentials used for repeat transactions	[Yes / No]
Refunds and adjustments	Refund processing through [payment platform / acquirer portal]	Yes
Administrative access	Management access to payment applications, infrastructure, and security tools	Yes
Settlement and reconciliation	Transaction reconciliation using [finance system / acquirer portal]	Yes

Cardholder Data Environment Overview

The cardholder data environment consists of the components that directly handle account data and the supporting security infrastructure that protects those components.

Environment Area	In-Scope Components
Network infrastructure	Firewalls, routers, switches, wireless infrastructure where applicable, load balancers, network management tools
Security infrastructure	Identity platforms, multi-factor authentication services, logging platforms, security monitoring tools, vulnerability management platforms, endpoint security tools
Server infrastructure	Physical servers, virtual servers, hypervisors, containers, cloud workloads, database servers, management hosts
Payment applications	[Payment Application Name], [E-commerce Platform], [POS Application], [Gateway Integration]
Databases and storage	Transaction databases, token vaults, file storage locations, backup repositories
End-user systems	Administrator workstations, call centre systems, jump hosts, support desktops with access to in-scope systems
Cloud services	[Cloud Provider], [Cloud Account / Subscription], hosted payment services, managed security services
Facilities	[Data Centre], [Head Office], [Retail Locations], [Call Centre], [Cloud Hosting Region]
Third-party services	Payment processors, payment gateways, managed service providers, hosting providers, support vendors, scanning vendors

Account Data Flows

The following table summarises the assessed cardholder data flows. Detailed data flow diagrams were reviewed during the assessment and are maintained by [Organisation Name] in [repository / GRC system / architecture library].

Flow ID	Source	Transmission Method	Destination	Account Data Present	Protection Method
DF-01	Customer browser	HTTPS	[E-commerce Platform / Payment Page]	[Cardholder data / Redirected only / Token only]	TLS, hosted payment fields, tokenisation

Flow ID	Source	Transmission Method	Destination	Account Data Present	Protection Method
DF-02	[E-commerce Platform]	API over TLS	[Payment Gateway]	[PAN / Token / Authorisation data]	Encrypted API connection, authentication, restricted endpoints
DF-03	POS terminal	Encrypted payment channel	[Processor / Acquirer]	Encrypted card data	Point-to-point encryption, terminal controls
DF-04	Call centre agent	Secure payment interface	[Payment Platform]	[PAN entered directly / DTMF masking / Token]	Role-based access, masking, monitoring
DF-05	[Payment Platform]	Secure batch transfer	[Finance / Reconciliation System]	Truncated PAN / token / transaction reference	Data minimisation, access restriction
DF-06	[In-scope Systems]	Backup transfer	[Backup Repository]	[Encrypted backups containing account data]	Encryption, access control, retention controls

In-Scope Locations

Location	Function	Included Scope Rationale
[Head Office]	Finance, compliance, administration	Personnel and systems supporting payment operations
[Call Centre]	Telephone payment handling	Cardholder data may be entered or processed by agents
[Retail Location(s)]	Card-present payment acceptance	POS terminals and local network connectivity
[Data Centre / Hosting Facility]	Hosting of payment systems	Infrastructure stores, processes, transmits, or supports account data
[Cloud Region / Provider]	Hosted payment applications and security services	Cloud workloads and services form part of the payment environment
[Disaster Recovery Site]	Recovery of payment services	Standby infrastructure may contain or process account data

In-Scope Service Providers

Service Provider	Service Provided	Impact on Cardholder Data Security	Responsibility Managed Through
[Payment Gateway]	Authorisation and payment processing	Processes account data and returns tokens / responses	Contract, compliance attestation, responsibility matrix
[Acquirer / Processor]	Settlement and transaction processing	Processes payment transactions	Service agreement, compliance validation
[Cloud Provider]	Hosting and infrastructure services	Provides underlying platform controls	Shared responsibility model, compliance reports
[Managed Security Provider]	Monitoring, alerting, security operations	Supports detection and response	Contract, service reporting, access controls
[Approved Scanning Vendor]	External vulnerability scanning	Performs required external scans	Scan reports, remediation tracking
[POS Support Vendor]	Terminal support and maintenance	May access payment infrastructure	Access approval, monitoring, vendor compliance review

Out-of-Scope Systems and Rationale

The following systems were excluded from the assessed scope based on segmentation, absence of account data, and lack of security impact on the cardholder data environment. Segmentation controls were reviewed as part of the assessment.

System / Environment	Rationale for Exclusion	Validation Performed
[Corporate HR System]	No storage, processing, or transmission of account data; no connectivity to in-scope segments	Network diagrams, firewall rules, interviews
[General Corporate LAN]	Segmented from cardholder data environment	Segmentation testing, access control review
[Marketing Platform]	Uses anonymised or non-payment data only	Data flow review, configuration review

System / Environment	Rationale for Exclusion	Validation Performed
[Development Environment]	Does not contain live account data and is separated from production	Data handling review, access review, environment walkthrough
[Public Website Content Platform]	Does not accept or redirect payment data except through approved integration	Architecture review, payment flow validation

Scope Assumptions and Limitations

The assessment conclusions are based on the scope, evidence, interviews, observations, and technical testing performed during the assessment period. Any material changes to payment channels, system architecture, third-party services, cardholder data flows, or segmentation after the assessment period may affect the conclusions in this report.

The following assumptions were applied:

- Management provided complete and accurate information regarding payment processes, systems, data flows, and third-party relationships.
- Evidence supplied during the assessment period was representative of normal operating practices.
- Systems identified as out of scope remain segmented from the cardholder data environment.
- Service provider compliance information reviewed was current and applicable to the services used by [Organisation Name].
- Temporary compensating or remediation measures, where relied upon, remain in operation until permanent corrective action is completed.

Executive Summary

Overall Assessment Conclusion

Based on the evidence reviewed, interviews conducted, observations performed, and technical validation completed during the assessment period, [Organisation Name] was assessed as:

Overall Status: [Compliant / Compliant with Compensating Controls / Not Compliant Pending Remediation]

Result Category	Count	Summary
In place	[Number]	Controls were implemented, operating, and supported by evidence
Not in place	[Number]	Controls were missing, incomplete, ineffective, or not sufficiently evidenced
Not applicable	[Number]	Requirements did not apply to the assessed environment based on documented rationale
Compensating controls	[Number]	Alternative controls were used where the stated control could not be met directly
Targeted risk analysis used	[Number]	Risk-based frequencies or approaches were supported by documented analysis

Key Strengths

The assessment identified the following areas of strength:

- [Organisation Name] maintains documented cardholder data flows and network diagrams that align to the assessed payment processes.

- External-facing payment services use encrypted communication channels and are subject to regular vulnerability scanning.
- Access to in-scope administrative systems is restricted to approved personnel and protected using multi-factor authentication.
- Security logging is centralised for key in-scope systems and reviewed by [Security Operations Team / Managed Security Provider].
- Service provider relationships are tracked, and compliance attestations are collected for critical payment service providers.
- Cardholder data storage is limited to approved systems, with masking, truncation, encryption, or tokenisation used where appropriate.
- Incident response responsibilities for payment-related security events are documented and tested.

Key Findings Requiring Attention

The assessment identified the following notable findings:

Finding ID	Summary	Severity	Status
ROC-F-001	[Example: Evidence of periodic review of firewall and router rules was incomplete for the full reporting period]	Medium	[Open / Remediated / In Progress]
ROC-F-002	[Example: Asset inventory did not consistently identify ownership and security classification for all in-scope components]	Medium	[Open / Remediated / In Progress]
ROC-F-003	[Example: Quarterly internal vulnerability scan remediation evidence was incomplete for selected systems]	High	[Open / Remediated / In Progress]
ROC-F-004	[Example: Service provider responsibility matrix required update for new cloud-based payment service]	Medium	[Open / Remediated / In Progress]
ROC-F-005	[Example: Evidence of secure coding training completion was not available for all developers supporting payment applications]	Low	[Open / Remediated / In Progress]

Compliance Readiness Summary

Domain Area	Assessment Summary	Readiness
Network security	Segmentation and boundary controls are defined; periodic review evidence requires strengthening where noted	[Green / Amber / Red]
Secure configuration	Baseline configurations exist for major platforms; exceptions require improved approval tracking	[Green / Amber / Red]
Account data protection	Storage is limited; encryption and masking controls are generally effective	[Green / Amber / Red]
Vulnerability management	Scanning processes are operating; remediation evidence requires consistent retention	[Green / Amber / Red]
Access control	Role-based access and multi-factor authentication are in place for in-scope access	[Green / Amber / Red]
Logging and monitoring	Centralised logging is implemented; alert handling procedures require periodic testing evidence	[Green / Amber / Red]
Security testing	External scans, penetration testing, and segmentation testing are performed as required	[Green / Amber / Red]
Governance and policy	Security policies exist and are communicated; some operational procedures need refresh	[Green / Amber / Red]

Domain Area	Assessment Summary	Readiness
Service provider management	Key providers are tracked; responsibility documentation requires updates for new services	[Green / Amber / Red]
Incident response	Payment incident response plan exists and has been exercised	[Green / Amber / Red]

Management Representation

Management of [Organisation Name] represented that:

- The assessment scope is complete and accurate.
- All known locations where account data is stored, processed, or transmitted have been disclosed.
- All relevant payment channels and supporting technologies have been included.
- No known repositories of unencrypted account data exist outside approved locations.
- All in-scope service providers have been identified.
- All evidence provided to the QSA was complete and not intentionally altered or withheld.

Methodology

Assessment Approach

The assessment was performed by [QSA Company Name] using a risk-based, evidence-led approach appropriate for a full PCI DSS v4.0.1 Report on Compliance.

The methodology included:

- Planning and scope confirmation.
- Review of payment channels and account data flows.
- Identification of systems, people, processes, facilities, and service providers in scope.
- Review of segmentation and scoping controls.
- Collection and evaluation of policies, procedures, standards, inventories, diagrams, logs, tickets, reports, and system records.
- Interviews with personnel responsible for governance, operations, development, security, infrastructure, and payment processing.
- Observation of control operation where applicable.
- Sampling of systems, users, events, changes, vulnerabilities, access reviews, and service provider records.
- Technical validation of selected configurations and security controls.
- Review of remediation evidence for findings identified during the assessment.
- Preparation of this Report on Compliance and supporting assessment workpapers.

Evidence Sources

Evidence reviewed included, but was not limited to:

Evidence Type	Examples Reviewed
Governance documentation	Security policies, standards, procedures, risk assessments, management approvals
Scope documentation	Network diagrams, data flow diagrams, asset inventories, payment process descriptions
Technical configurations	Firewall rules, system hardening settings, encryption settings, authentication settings
Identity and access records	User lists, administrator accounts, access approvals, access review evidence
Vulnerability records	Internal scans, external scans, remediation tickets, retest results, penetration test reports
Logging and monitoring records	SIEM logs, alert records, incident tickets, daily monitoring evidence
Change records	Change approvals, implementation records, testing evidence, emergency change records
Development records	Secure coding standards, code review evidence, application testing results
Service provider records	Contracts, compliance attestations, responsibility matrices, due diligence records
Training records	Security awareness completion, role-based training, developer training
Incident response records	Incident response plan, test results, lessons learned, contact lists
Backup and recovery records	Backup schedules, restore tests, retention settings, encryption settings

Interviewed Roles

The following roles or equivalent personnel were interviewed:

Role / Team	Topics Covered
Chief Information Security Officer / Security Lead	Security governance, risk management, incident response, compliance oversight
PCI Program Manager	Scope, evidence coordination, remediation tracking, reporting
Network Engineering	Segmentation, firewall rules, network architecture, remote access
Infrastructure Operations	Server configuration, patching, backups, administrative access
Cloud Operations	Cloud account structure, identity, logging, network security, shared responsibility
Application Development	Secure development, code review, testing, deployment process
Database Administration	Data storage, encryption, access control, backup handling
Security Operations	Logging, alerting, vulnerability management, incident triage
Service Desk / Identity Administration	User provisioning, deprovisioning, access changes
Finance / Reconciliation	Settlement, refunds, reporting, acquirer portal access
Contact Centre / Retail Operations	Payment handling procedures, terminal controls, staff training
Vendor Management / Procurement	Service provider due diligence, contracts, compliance evidence

Sampling Method

Sampling was applied where populations were large and where a representative set of evidence was appropriate to validate control design and operating effectiveness.

Sampling considered:

- System criticality.
- Payment data exposure.
- Technology type.
- Location.

- Administrative access level.
- Time coverage across the reporting period.
- Recent changes or incidents.
- Prior assessment findings.
- Service provider dependency.
- Risk indicators from vulnerability or monitoring data.

Sample selections were documented in assessment workpapers. Where a sample exception indicated a possible systemic issue, additional evidence was requested and reviewed.

Technical Validation Performed

Technical validation included the following activities where applicable:

Validation Area	Activity
Network segmentation	Review of segmentation design, firewall rules, routing, and segmentation test results
External exposure	Review of internet-facing assets, external scan results, and remediation records
System configuration	Review of selected server, network, database, endpoint, and cloud configurations
Encryption	Review of encryption methods for transmission and storage of account data
Authentication	Review of password settings, multi-factor authentication, session controls, and privileged access
Logging	Review of log sources, alerting rules, retention settings, and monitoring records
Vulnerability management	Review of scan schedules, results, remediation actions, and retest evidence
Application security	Review of development practices, code review, testing records, and deployment controls
Physical security	Review of access restrictions and visitor controls at relevant facilities
Data discovery	Review of processes and tools used to identify stored account data

Assessment Result Definitions

Result	Definition
In place	The control was implemented, operating as intended, and supported by sufficient evidence
Not in place	The control was absent, incomplete, ineffective, or not supported by sufficient evidence
Not applicable	The control did not apply to the assessed environment, and the rationale was validated
In place with compensating control	The stated control could not be met directly, but an alternative set of controls sufficiently addressed the risk
Not tested	The item was not tested because it was outside the validated scope or not applicable to the organisation

Detailed Findings / Results (with structure)

Results Summary by Control Area

Control Area	Result	Summary of Assessment Outcome
Network security controls	[In Place / Not In Place / Mixed]	Firewalls and segmentation are implemented to restrict traffic to necessary business flows. Rule review evidence requires improvement where noted.
Secure configurations	[In Place / Not In Place / Mixed]	Secure baseline standards exist for major platforms. Some exception tracking and evidence retention gaps were identified.
Account data protection	[In Place / Not In Place / Mixed]	Cardholder data storage is limited and protected through masking, encryption, truncation, or tokenisation. Data discovery procedures are in place.
Encrypted transmission	[In Place / Not In Place / Mixed]	Public and private transmissions of account data use strong encryption and trusted communication channels.
Malware protection	[In Place / Not In Place / Mixed]	Endpoint protection is deployed to applicable systems, with alerting and update mechanisms in place.
Secure application development	[In Place / Not In Place / Mixed]	Secure coding and change control practices are defined. Evidence of role-based developer training requires improvement where noted.
Vulnerability management	[In Place / Not In Place / Mixed]	Internal and external scanning processes operate on a recurring basis. Some remediation records require stronger linkage to retesting.
Access control	[In Place / Not In Place / Mixed]	Access is role-based, approved, and reviewed. Privileged access is limited and protected using multi-factor authentication.
Authentication management	[In Place / Not In Place / Mixed]	Authentication settings support secure access. Shared and default accounts are restricted or removed.
Physical security	[In Place / Not In Place / Mixed]	Facilities supporting payment processing are physically restricted and monitored. Visitor handling procedures are documented.
Logging and monitoring	[In Place / Not In Place / Mixed]	Logs are collected centrally for critical systems. Alert review evidence is maintained by the security operations function.
Security testing	[In Place / Not In Place / Mixed]	Penetration testing, segmentation testing, and vulnerability scanning are performed. Retesting is tracked following remediation.
Security policies and governance	[In Place / Not In Place / Mixed]	Policies and procedures are maintained and communicated. Responsibility assignments are documented.
Service provider management	[In Place / Not In Place / Mixed]	Service providers are tracked and reviewed. Responsibility documentation requires updates for recently added services.
Incident response	[In Place / Not In Place / Mixed]	Incident response processes are documented, tested, and include payment-related escalation requirements.

Finding Register

Finding ID	Control Area	Finding	Risk	Severity	Status	Owner	Target Date
ROC-F-001	Network security	Periodic review evidence for firewall and router rules was incomplete for [period / devices].	Unnecessary or outdated access paths may remain active, increasing exposure to unauthorised access.	Medium	[Open / Remediated]	[Owner]	[Date]

Finding ID	Control Area	Finding	Risk	Severity	Status	Owner	Target Date
ROC-F-002	Asset management	The in-scope asset inventory did not consistently include owner, function, and security classification for all sampled assets.	Incomplete inventory data may impair patching, monitoring, access control, and incident response.	Medium	[Open / Remediated]	[Owner]	[Date]
ROC-F-003	Vulnerability management	Evidence did not consistently show that selected internal scan findings were remediated and retested within the expected timeframe.	Known weaknesses may remain exploitable for longer than intended.	High	[Open / Remediated]	[Owner]	[Date]
ROC-F-004	Service provider management	Responsibility documentation was not updated to reflect the introduction of [new service provider / cloud service].	Control ownership may be misunderstood, leading to gaps in operation or evidence collection.	Medium	[Open / Remediated]	[Owner]	[Date]
ROC-F-005	Secure development	Secure coding training completion evidence was not available for all sampled developers supporting payment applications.	Developers may not consistently apply secure coding practices, increasing application security risk.	Low	[Open / Remediated]	[Owner]	[Date]
ROC-F-006	Logging and monitoring	Selected systems were not clearly mapped to log source onboarding records in the central monitoring platform.	Security events from in-scope systems may not be monitored or investigated promptly.	Medium	[Open / Remediated]	[Owner]	[Date]
ROC-F-007	Evidence management	Some recurring control activities were performed but evidence was retained inconsistently.	Management may be unable to demonstrate control operation during future assessments.	Low	[Open / Remediated]	[Owner]	[Date]

Detailed Finding - ROC-F-001: Firewall and Router Rule Review Evidence

Attribute	Detail
Finding ID	ROC-F-001
Area	Network security
Severity	Medium
Status	[Open / Remediated / In Progress]
Affected systems	[Firewalls / routers / cloud security groups]
Owner	[Network Security Owner]
Target remediation date	[Date]

Condition

The assessment found that firewall and router rule reviews were performed for some in-scope devices; however, evidence was incomplete for [specific period / device set]. In particular, review records did not consistently show reviewer identity, date of review, rule justification, disposition of obsolete rules, or approval of retained exceptions.

Risk

Without complete rule review evidence, unnecessary access may remain permitted into or within the cardholder data environment. This increases the risk of unauthorised access, lateral movement, and exposure of account data.

Evidence Reviewed

- Network diagrams dated [Date].
- Firewall configuration exports from [Device / Platform].
- Rule review tickets [Ticket IDs].
- Change records [Change IDs].
- Interview with [Network Engineering Role] on [Date].

Root Cause

The rule review process exists but is not consistently supported by a standard evidence template or centralised tracking workflow.

Management Response

[Management response]

Corrective Action

- Implement a standard rule review template.
- Require documented business justification for each retained rule.
- Track obsolete or excessive rules through change management until removed.
- Retain completed reviews in [GRC tool / ticketing system / repository].
- Perform management review of overdue remediation actions.

Detailed Finding - ROC-F-002: Incomplete Asset Inventory Attributes

Attribute	Detail
Finding ID	ROC-F-002
Area	Asset management
Severity	Medium
Status	[Open / Remediated / In Progress]
Affected systems	[Asset inventory / CMDB / cloud inventory]
Owner	[IT Asset Owner]
Target remediation date	[Date]

Condition

The in-scope asset inventory included hostnames and IP addresses for most sampled systems, but selected records lacked complete owner, business function, technology role, environment, and security classification information.

Risk

Incomplete asset information may result in systems being missed during patching, scanning, access reviews, logging onboarding, backup configuration, or incident response.

Evidence Reviewed

- Asset inventory export dated [Date].
- Cloud asset listing from [Cloud Provider].
- Vulnerability scanner asset list.
- Configuration management database records.
- Interviews with [Infrastructure Owner] and [Security Operations Lead].

Root Cause

Asset discovery data is collected from multiple tools, but reconciliation and ownership validation are not consistently performed.

Management Response

[Management response]

Corrective Action

- Define mandatory fields for all in-scope assets.
- Reconcile asset inventory against vulnerability scanner, cloud platform, endpoint management, and network discovery sources.
- Assign accountable owners for all in-scope assets.
- Review asset records at least quarterly and after major changes.
- Report inventory completeness metrics to the PCI governance forum.

Detailed Finding - ROC-F-003: Vulnerability Remediation and Retesting Evidence

Attribute	Detail
Finding ID	ROC-F-003
Area	Vulnerability management
Severity	High
Status	[Open / Remediated / In Progress]
Affected systems	[System names / scanner groups]
Owner	[Vulnerability Management Owner]
Target remediation date	[Date]

Condition

Internal vulnerability scans are performed on a recurring basis; however, for selected findings, evidence did not consistently demonstrate that remediation was completed and confirmed through retesting within the organisation's defined timeframe.

Risk

Known vulnerabilities may remain exploitable, increasing the likelihood of compromise of in-scope systems or supporting infrastructure.

Evidence Reviewed

- Internal vulnerability scan reports dated [Dates].
- Remediation tickets [Ticket IDs].
- Retest results dated [Dates].
- Patch deployment records.
- Interviews with [Vulnerability Manager] and [Infrastructure Operations].

Root Cause

Remediation ownership and retest closure criteria are not consistently enforced across all infrastructure teams.

Management Response

[Management response]

Corrective Action

- Assign remediation owners based on asset ownership.
- Define closure criteria requiring successful retest or documented risk acceptance.
- Configure ticket workflow to prevent closure without supporting evidence.
- Escalate overdue findings to management.
- Produce monthly vulnerability remediation metrics for in-scope assets.

Detailed Finding - ROC-F-004: Service Provider Responsibility Documentation

Attribute	Detail
Finding ID	ROC-F-004
Area	Service provider management
Severity	Medium
Status	[Open / Remediated / In Progress]
Affected services	[Service Provider / Cloud Service / Payment Platform]
Owner	[Vendor Management Owner]
Target remediation date	[Date]

Condition

The organisation maintains a register of service providers that may affect account data security. However, responsibility documentation had not been updated to reflect [new service provider / material service change], including ownership of logging, vulnerability management, incident notification, access administration, and data protection controls.

Risk

Unclear responsibilities may lead to control gaps, delayed incident response, incomplete evidence collection, or assumptions that security tasks are being performed by another party.

Evidence Reviewed

- Service provider register dated [Date].
- Contract and service description for [Provider].
- Compliance attestation for [Provider].
- Shared responsibility documentation.
- Interviews with [Vendor Manager] and [Cloud Operations Lead].

Root Cause

Vendor onboarding did not require PCI responsibility mapping before production use.

Management Response

[Management response]

Corrective Action

- Update the service provider responsibility matrix.
- Require PCI impact review during vendor onboarding and service changes.
- Confirm incident notification timelines and security evidence obligations in contract terms.
- Review service provider compliance attestations annually.
- Track responsibility updates through the PCI governance forum.

Detailed Finding - ROC-F-005: Secure Coding Training Evidence

Attribute	Detail
Finding ID	ROC-F-005
Area	Secure application development
Severity	Low
Status	[Open / Remediated / In Progress]
Affected personnel	[Development team / application team]
Owner	[Application Security Owner]
Target remediation date	[Date]

Condition

Secure coding standards are documented and code review practices are in place. However, training completion evidence was unavailable for [number] sampled developers who support payment applications.

Risk

Developers without current secure coding training may introduce avoidable vulnerabilities into payment applications.

Evidence Reviewed

- Secure coding standard dated [Date].
- Developer training records.
- Learning management system export.

- Code review records.
- Interviews with [Development Manager] and [Application Security Lead].

Root Cause

Training completion tracking is not fully integrated with developer onboarding and annual role-based training requirements.

Management Response

[Management response]

Corrective Action

- Update developer onboarding checklist to include secure coding training.
- Require annual role-based application security training.
- Track completion through [Learning Management System].
- Escalate overdue training to development management.
- Retain training evidence for all developers with payment application responsibilities.

Detailed Finding - ROC-F-006: Log Source Mapping

Attribute	Detail
Finding ID	ROC-F-006
Area	Logging and monitoring
Severity	Medium
Status	[Open / Remediated / In Progress]
Affected systems	[SIEM / log platform / in-scope systems]
Owner	[Security Operations Owner]
Target remediation date	[Date]

Condition

Centralised logging is in place for critical systems. However, selected in-scope systems were not clearly mapped to log source onboarding records, making it difficult to confirm whether all required logs are collected, retained, and monitored.

Risk

Important security events may not be detected or investigated in a timely manner if log coverage is incomplete or undocumented.

Evidence Reviewed

- SIEM log source inventory.
- Asset inventory.
- Alert rules and dashboards.
- Log retention settings.
- Interviews with [Security Operations Lead].

Root Cause

Log onboarding is performed during system deployment, but periodic reconciliation between the asset inventory and log source inventory is not consistently documented.

Management Response

[Management response]

Corrective Action

- Reconcile in-scope assets against SIEM log source inventory.
- Document required log types by system category.
- Establish periodic log source health checks.
- Report missing or inactive log sources to system owners.
- Retain evidence of reconciliation and remediation.

Detailed Finding - ROC-F-007: Recurring Control Evidence Retention

Attribute	Detail
Finding ID	ROC-F-007
Area	Evidence management
Severity	Low
Status	[Open / Remediated / In Progress]
Affected processes	[Access reviews / rule reviews / monitoring reviews / training evidence]
Owner	[PCI Program Manager]
Target remediation date	[Date]

Condition

Several recurring control activities were described and, in some cases, demonstrated through interviews or system records. However, evidence retention was inconsistent across teams, particularly for recurring reviews and approvals.

Risk

Control activities may be operating but cannot be reliably demonstrated during audits or investigations. This may result in unnecessary compliance findings and reduced management confidence.

Evidence Reviewed

- Access review records.
- Firewall review records.
- Vulnerability tickets.
- Monitoring review evidence.
- Interviews with control owners.

Root Cause

Evidence retention expectations are not consistently defined by control activity, owner, location, and retention period.

Management Response

[Management response]

Corrective Action

- Define an evidence retention matrix for PCI recurring controls.
- Assign evidence owners for each recurring activity.
- Use [GRC platform / document repository / ticketing system] as the authoritative evidence location.
- Conduct monthly evidence completeness checks.
- Report missing evidence to the PCI governance forum.

Not Applicable Areas

The following areas were assessed as not applicable based on the organisation's payment architecture and validated scope.

Area	Rationale	Validation Performed
Storage of sensitive authentication data after authorisation	[Organisation Name] does not store full magnetic stripe data, card verification codes, PINs, or equivalent sensitive authentication data after authorisation.	Data flow review, database review, process interviews, data discovery evidence
Wireless payment network	[Organisation Name] does not use wireless networks for payment processing within the assessed environment.	Network diagrams, wireless controller review, site interviews
Custom payment application storage of full PAN	[Payment Application] uses tokenisation and does not store full PAN.	Application architecture review, database queries, tokenisation documentation
Manual paper storage of cardholder data	[Organisation Name] does not retain paper forms containing cardholder data.	Process walkthrough, records retention review, interviews
In-house cryptographic key injection for payment terminals	Key injection is performed by [approved provider / processor], not by [Organisation Name].	Service provider documentation, terminal management process review

Compensating Controls

Where direct implementation of a stated control was not feasible due to legitimate technical or business constraints, compensating controls were assessed to determine whether they sufficiently addressed the associated risk.

Compensating Control ID	Related Area	Constraint	Alternative Controls	Result
CC-001	[Area]	[Describe legitimate constraint]	[Describe layered alternative controls]	[Accepted / Not Accepted / Not Used]
CC-002	[Area]	[Describe legitimate constraint]	[Describe layered alternative controls]	[Accepted / Not Accepted / Not Used]

For each accepted compensating control, assessment workpapers include:

- Business or technical constraint.
- Risk analysis.
- Description of alternative controls.
- Evidence of control design and operation.
- Validation that the alternative controls provide equivalent risk reduction.
- Management approval.

- Monitoring and review requirements.

Targeted Risk Analysis

Where risk-based frequencies or customised approaches were used, [Organisation Name] maintained documented analysis supporting the selected approach.

Analysis ID	Area	Decision Supported	Evidence Reviewed	Result
TRA-001	[Example: Log review frequency]	[Frequency / method]	Risk analysis, threat context, asset criticality, monitoring capability	[Accepted / Requires Update]
TRA-002	[Example: Vulnerability scan frequency for specific environment]	[Frequency / method]	System criticality, exposure, change frequency, prior findings	[Accepted / Requires Update]
TRA-003	[Example: Account review frequency]	[Frequency / method]	Access population, privilege level, compensating monitoring	[Accepted / Requires Update]

The targeted risk analyses reviewed were assessed for:

- Clearly defined asset or process scope.
- Identification of threats and potential impacts.
- Consideration of likelihood and business context.
- Defined review frequency or control approach.
- Management approval.
- Review after significant changes.

Analysis

Overall Control Environment

[Organisation Name] has established a defined PCI compliance program supported by policies, technical controls, operational processes, and management oversight. The assessed environment demonstrates a deliberate effort to minimise account data exposure through tokenisation, encryption, segmentation, access restriction, and use of specialised payment service providers.

The strongest areas observed were access control, encrypted transmission, payment data minimisation, and centralised security monitoring. The primary areas requiring management focus relate to consistency of evidence retention, formal tracking of recurring reviews, timely closure of vulnerability remediation activities, and maintenance of service provider responsibility documentation as the payment architecture changes.

Scope and Segmentation Analysis

The assessment confirmed that [Organisation Name] maintains documented data flows and network diagrams for the assessed payment channels. Segmentation is used to separate the cardholder data environment from broader corporate networks and systems.

Segmentation effectiveness depends on continued operation of:

- Firewall and routing controls.
- Restricted administrative access paths.

- Controlled remote access.
- Jump host or bastion access where applicable.
- Network monitoring.
- Periodic segmentation testing.
- Change control for network rule changes.

The organisation should treat segmentation as a critical compliance dependency. Weaknesses in review evidence do not necessarily indicate segmentation failure, but they reduce assurance that segmentation remains effective over time.

Account Data Storage and Protection Analysis

The assessed environment limits storage of account data to approved systems. The organisation uses one or more of the following techniques:

- Tokenisation.
- Truncation.
- Masking.
- Strong encryption.
- Secure payment redirection or hosted payment capture.
- Restricted display of account data based on business need.
- Retention limits and disposal procedures.

The assessment did not identify unauthorised storage of sensitive authentication data after authorisation based on the evidence reviewed. Continued data discovery activities remain important, especially following system changes, new reporting processes, support activities, or exports used for reconciliation.

Access Control Analysis

Access controls are generally well designed. Administrative access is restricted and protected using multi-factor authentication. User access is granted through approved processes and reviewed periodically.

Areas for continued management attention include:

- Ensuring access reviews are completed on time.
- Retaining evidence of reviewer decisions.
- Promptly removing access for terminated or transferred personnel.
- Monitoring privileged access activity.
- Avoiding shared administrative accounts.
- Confirming service provider access is approved, time-bound, and monitored.

Vulnerability Management Analysis

The vulnerability management program includes recurring internal and external scanning, remediation tracking, and retesting. The assessment found that the process is functioning, but evidence linkage between scan results, remediation tickets, and successful retests requires improvement.

A mature vulnerability program should provide clear traceability from:

- Vulnerability detection.
- Risk rating.
- Assignment to owner.
- Remediation action.
- Retest result.
- Closure approval.
- Exception or risk acceptance where applicable.

The organisation should prioritise high-risk vulnerabilities affecting internet-facing systems, systems storing or processing account data, privileged access platforms, and security control infrastructure.

Logging and Monitoring Analysis

Centralised logging and monitoring are implemented for key in-scope systems. Security operations personnel or a managed security provider review alerts and escalate events through incident management processes.

The main improvement opportunity is stronger reconciliation between the in-scope asset inventory and monitored log sources. This will help ensure that all critical systems are sending logs, logs are retained appropriately, and failures in log ingestion are detected quickly.

Secure Development and Change Management Analysis

Secure development and change management controls are defined for payment applications and supporting integrations. The organisation maintains secure coding standards, code review practices, test procedures, and deployment controls.

Management should ensure that:

- All developers supporting payment applications receive current secure coding training.
- Security testing is integrated into the development lifecycle.
- Emergency changes are retrospectively reviewed.
- Production access for developers is restricted and monitored.
- Payment page scripts, third-party components, and integrations are reviewed for integrity and security impact.
- Application changes that affect payment flows trigger scope and risk review.

Service Provider Management Analysis

[Organisation Name] relies on external providers for payment processing, hosting, security operations, scanning, or other in-scope services. Service provider assurance is therefore a critical element of the control environment.

The assessment found that major providers are identified and compliance documentation is collected. However, responsibility mapping must be kept current as new services are introduced. This is particularly important for cloud

services and managed platforms where security responsibilities are shared between the provider and [Organisation Name].

Governance and Evidence Analysis

The organisation has assigned ownership for PCI compliance activities and maintains policies and procedures covering the cardholder data environment. The most significant cross-cutting issue is evidence consistency.

Evidence gaps often arise when teams perform activities but do not retain proof in a standard way. This creates unnecessary compliance risk and may obscure whether controls are operating consistently.

An evidence management model should define:

- Control activity.
- Frequency.
- Owner.
- Required evidence.
- Evidence format.
- Storage location.
- Retention period.
- Escalation path for missing evidence.

Risk Themes

The following risk themes were observed:

Risk Theme	Description	Business Impact
Evidence inconsistency	Control operation is not always supported by complete retained evidence	May result in avoidable compliance exceptions
Dynamic technology change	Cloud services, integrations, and payment platforms may change faster than documentation	May lead to incomplete scope or responsibility mapping
Vulnerability closure traceability	Remediation and retesting records are not always linked	May delay risk reduction and complicate audit validation
Segmentation dependency	Compliance scope relies on continued effectiveness of segmentation controls	Segmentation weakness could expand assessment scope significantly
Third-party reliance	Critical controls depend on service providers	Poor oversight may create unrecognised control gaps

Recommendations & Actions

Priority Action Plan

Priority	Action	Owner	Target Date	Success Criteria
1	Complete remediation and retesting for all outstanding high-risk vulnerability findings affecting in-scope systems.	[Vulnerability Management Owner]	[Date]	All high-risk findings closed with successful retest evidence or approved risk treatment
2	Reconcile in-scope asset inventory against scanner, cloud, endpoint, CMDB, and SIEM sources.	[Asset Management Owner]	[Date]	Asset inventory contains complete mandatory fields for all in-scope assets

Priority	Action	Owner	Target Date	Success Criteria
3	Update firewall and router rule review process and complete overdue reviews.	[Network Security Owner]	[Date]	All in-scope rule sets reviewed, justified, approved, and tracked
4	Update service provider responsibility matrix for all in-scope providers and new payment services.	[Vendor Management Owner]	[Date]	Responsibility matrix approved and stored in compliance repository
5	Confirm log source onboarding for all in-scope systems and resolve missing or inactive sources.	[Security Operations Owner]	[Date]	SIEM inventory reconciled with asset inventory and exceptions documented
6	Complete secure coding training for all developers supporting payment applications.	[Application Security Owner]	[Date]	Training completion records available for all applicable personnel
7	Implement a PCI evidence retention matrix and monthly evidence completeness review.	[PCI Program Manager]	[Date]	Evidence repository contains current records for all recurring control activities

Remediation Tracking

Remediation actions should be tracked in [GRC Tool / Ticketing System] with the following minimum fields:

Field	Required Content
Finding ID	Unique identifier from this report
Finding description	Summary of the issue
Severity	High, medium, or low
Control owner	Individual accountable for remediation
Action plan	Specific corrective actions
Due date	Management-approved target date
Status	Open, in progress, remediated, risk accepted, or closed
Evidence required	Documents, screenshots, reports, tickets, logs, or approvals needed
Validation owner	Person responsible for confirming completion
Closure date	Date validated and closed
Residual risk	Remaining risk after remediation, if any

Recommended Governance Cadence

Activity	Recommended Frequency	Owner	Output
PCI governance meeting	Monthly	[PCI Program Manager]	Action log, risk decisions, remediation status
Scope review	Quarterly and after significant change	[Compliance Owner]	Updated scope statement and diagrams
Asset inventory reconciliation	Quarterly	[Asset Management Owner]	Reconciled inventory report
Vulnerability remediation review	Monthly	[Security Operations Owner]	Aging report and escalation list
Service provider review	Annually and upon material change	[Vendor Management Owner]	Updated provider register and responsibility matrix
Access review	At defined recurring intervals	[Identity Owner]	Completed review records and removals
Firewall and segmentation review	At defined recurring intervals and after major changes	[Network Security Owner]	Rule review evidence and test results
Incident response exercise	At least annually	[Security Lead]	Exercise report and lessons learned
Evidence completeness review	Monthly	[PCI Program Manager]	Evidence gap report

Management Acceptance and Closure

Management should formally review this report and approve the remediation plan. Findings should not be closed until sufficient evidence demonstrates that corrective action has been implemented and is operating as intended.

Closure evidence may include:

- Updated policies, procedures, standards, or diagrams.
- Configuration exports.
- System screenshots.
- Change tickets.
- Vulnerability retest results.
- Access review records.
- Training completion records.
- Service provider documentation.
- Meeting minutes.
- Management approvals.
- Independent validation by internal audit, compliance, or the QSA where required.

Continuous Compliance Recommendations

To maintain compliance beyond the assessment date, [Organisation Name] should:

- Integrate PCI scope review into technology change management.
- Maintain real-time or frequently reconciled asset inventories.
- Use automated evidence collection where feasible.
- Ensure payment-related changes trigger security and compliance review.
- Maintain current data flow diagrams and network diagrams.
- Validate that no unauthorised account data storage is introduced.
- Review service provider compliance status before renewal and after material change.
- Monitor emerging threats affecting payment applications and infrastructure.
- Maintain executive visibility of PCI risks and remediation status.
- Treat compliance as an ongoing operational discipline rather than an annual assessment event.

Distribution & Confidentiality

Distribution List

This report contains sensitive information about [Organisation Name]'s payment environment, security controls, vulnerabilities, architecture, and third-party relationships. Distribution must be restricted to authorised recipients with a legitimate business need.

Recipient / Group	Organisation	Purpose
[Executive Sponsor]	[Organisation Name]	Executive oversight
[PCI Program Manager]	[Organisation Name]	Compliance management
[Chief Information Security Officer]	[Organisation Name]	Security governance
[Technology Leadership]	[Organisation Name]	Remediation oversight
[Internal Audit]	[Organisation Name]	Assurance and follow-up
[Acquiring Bank / Processor Contact]	[Acquirer / Processor]	Compliance validation
[Payment Brand Contact, if applicable]	[Payment Brand]	Compliance validation
[QSA Company Contact]	[QSA Company Name]	Assessment record
[Legal Counsel, if applicable]	[Organisation Name]	Legal review and privilege considerations

Confidentiality Requirements

This report is classified as **Confidential - Restricted Distribution**.

Recipients must:

- Store the report only in approved secure repositories.
- Not forward the report without written approval from [Report Owner].
- Not share the report with unauthorised third parties.
- Protect printed copies from unauthorised viewing or removal.
- Delete or securely destroy local copies when no longer required.
- Report suspected unauthorised disclosure immediately to [Security Contact].
- Use the report only for compliance, assurance, remediation, or authorised business purposes.

Handling Instructions

Handling Area	Requirement
Electronic storage	Store in [approved repository / GRC platform] with access restricted to authorised users
Email transmission	Use encrypted email or approved secure transfer mechanism
Printed copies	Avoid printing unless necessary; store securely and shred when no longer required
Third-party sharing	Requires approval from [Report Owner / Legal / Compliance]
Retention period	Retain according to [records retention schedule], subject to legal or contractual obligations
Disposal	Secure deletion for electronic copies and confidential destruction for paper copies

Disclaimer

This report reflects assessment results for the defined scope and reporting period only. It does not guarantee that [Organisation Name] will remain compliant after the assessment date, nor does it provide assurance for systems, services, locations, or processes outside the assessed scope.

Compliance depends on the continued operation of controls, timely remediation of findings, management of changes, and ongoing monitoring of the cardholder data environment. Any significant change to payment processing, architecture, service providers, access paths, storage locations, or security controls should be reviewed for impact on PCI scope and compliance status.

Approval

Role	Name	Signature / Approval	Date
Executive Sponsor	[Name]	[Signature / Electronic Approval]	[Date]
PCI Program Manager	[Name]	[Signature / Electronic Approval]	[Date]
Chief Information Security Officer	[Name]	[Signature / Electronic Approval]	[Date]
Lead QSA	[Name]	[Signature / Electronic Approval]	[Date]
QSA Company Representative	[Name]	[Signature / Electronic Approval]	[Date]